REVUE DE PRESSE HEBDOMADAIRE

# Software Compliance

*L'essentiel de la conformité des logiciels embarqués dans les produits de défense*

N° 5 – Mardi 3 novembre 2026

Revue de presse hebdomadaire, tous les mardis

*Une faille critique de Brotli, bibliothèque de compression enfouie dans de nombreux logiciels, est activement exploitée ; une faille du noyau Linux rejoint le même catalogue de la CISA et une extension d'outil de développement a été piégée ; la règle des affiliés du BIS doit revenir le 10 novembre ; l'OFAC sanctionne des livraisons de logiciels à un fabricant de missiles russe.*

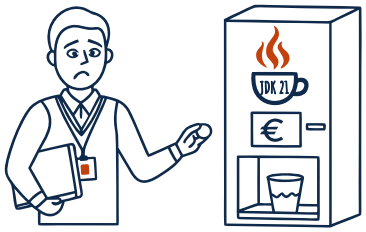
DANS CE NUMÉRO

SBOM et normes ..... 1
Outils ..... 2
Chaîne d'approvisionnement ..... 2
Commerce international ..... 3
France et UE ..... 3
Licences ..... 4
Glossaire ..... 4
Agenda ..... 4

À LA UNE

## Brotli, une faille exploitée dans un composant enfoui

Une faille critique de la bibliothèque de compression Brotli est activement exploitée ; souvent recopiée dans le code des logiciels, elle échappe aux inventaires fondés sur les paquets.




Oracle JDK 21 : les mises à jour publiées à partir du correctif trimestriel (CPU) d'octobre 2026, daté du 20 octobre, sont prévues sous licence Java SE OTN ; l'usage en production devient payant au-delà des autorisations gratuites de cette licence ; Oracle JDK 25 reste sous licence NFTC jusqu'en septembre 2028.

Jusqu'ici, JDK 21 était gratuit en production et redistribuable sous la licence NFTC (*No-Fee Terms and Conditions*). La licence OTN qui couvre ses versions 21.0.13 et suivantes en diffère substantiellement, selon Oracle : certains usages permis par les licences antérieures peuvent ne plus l'être.

Un équipement qui embarque en production ces nouveaux correctifs de JDK 21 entre dans le champ de la redevance : l'industriel doit recenser ses produits concernés, avec des SBOM qui distinguent Oracle JDK des distributions OpenJDK. Un produit maintenu plusieurs années pourrait devoir migrer vers JDK 25 ou vers une distribution OpenJDK, au prix d'une nouvelle qualification du logiciel.

EN BREF

**Java 8, 11 et 17** : les versions d'Oracle JDK sont déjà proposées sous licence OTN, gratuite pour les seuls usages personnels, de développement et assimilés.

**OpenJDK** : Oracle publie aussi sur jdk.java.net des versions de production sous licence GPLv2 avec exception *Classpath*, aujourd'hui JDK 27.

SBOM, NORMES ET RÉFÉRENTIELS

*Une nouvelle autorité de numérotation CVE couvre les projets de la Linux Foundation ; l'ETSI publie une spécification contre les hypertrucages ; CycloneDX 2.0 et les normes du CRA restent attendus.*

### AI Act : l'EN 18286, première norme harmonisée citée au Journal officiel

AI Act, première norme harmonisée : la Commission a annoncé le 19 octobre 2026 la publication au JO de la référence de l'EN 18286:2026 (système de management de la qualité), par la décision d'exécution (UE) 2026/2274 ; elle donne une présomption de conformité à l'article 17.

Élaborée par le CEN et le CENELEC, la norme suit tout le cycle de vie du système d'IA ; elle se superpose à ISO/IEC 42001 ou à ISO 9001 sans les remplacer. Elle répond au volet de la demande de normalisation du 23 juin 2025 consacré au management de la qualité, processus de surveillance après commercialisation compris.

Un fournisseur de système d'IA à haut risque peut désormais s'appuyer sur elle pour son système de management de la qualité. Le système exigé couvre notamment la notification des incidents graves et la gestion des ressources, sécurité d'approvisionnement comprise. Un fournisseur déjà tenu à un système qualité par une autre législation sectorielle de l'Union peut y intégrer ces exigences. Pour un produit à double usage qui intègre de l'IA, hors de l'exclusion défense, elle pourrait devenir une référence attendue par les clients civils.

La Commission annonce d'autres normes harmonisées avant l'application des exigences sur les systèmes à haut risque.

EN BREF

**CycloneDX 2.0** : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

**Normes du CRA** : 17 projets de normes verticales de l'ETSI en enquête publique jusqu'à mi-novembre 2026 ; aucune norme du CRA n'est encore citée au Journal officiel.

## OUTILS ET SERVICES DE CONFORMITÉ

*cdxgen repère les copies de Brotli dans les binaires ; Grype et Syft publient de nouvelles versions.*

### Trivy 0.76 : nouvelles sources de correctifs et CBOM enrichi

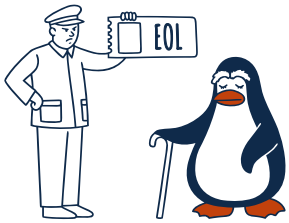
Trivy 0.76 : le scanneur d'Aqua Security détecte désormais les vulnérabilités des paquets Maven et npm corrigés par Echo, analyse les images RapidFort fondées sur Debian, Oracle Linux, Rocky Linux, AlmaLinux et Amazon Linux, et indique le niveau de sécurité nominal des algorithmes de sa nomenclature cryptographique (CBOM), fonction encore expérimentale.

Le niveau de sécurité se lit sur deux échelles : la résistance en bits aux attaques classiques et la catégorie post-quantique du NIST, de 1 à 5, ou 0 pour un algorithme qui n'en atteint aucune.

Publiée le 14 octobre, la version demande normalement une connexion Internet ; sa documentation décrit la configuration d'un réseau restreint ou entièrement isolé : les bases peuvent y être hébergées dans un registre interne, et Maven Central n'y est pas utilisable.

Les équipes qui comparent des CBOM successifs doivent prévoir le changement d'identifiant des composants DSA, la fonction pouvant évoluer sans garantie de rétrocompatibilité. Le niveau de sécurité nominal pourrait aider à repérer la cryptographie faible d'un produit et à documenter les fonctions de chiffrement examinées pour le contrôle des exportations.

### Syft 1.55 et Grype 0.121 : paquets IPK et fin de support des distributions




Syft 1.55 et Grype 0.121 : publiés le 19 octobre 2026 par Anchore, le générateur de SBOM inventorie désormais les paquets IPK, et le scanneur de vulnérabilités tient compte de la date de fin de support publiée par les distributions pour ses alertes de fin de vie.

Format du gestionnaire opkg, l'IPK reprend la structure des paquets deb : Syft le lit donc avec son catalogueur d'archives deb. Grype retrouve aussi les avis GitHub des paquets Swift Package Manager.

Les dates de fin de vie venaient jusqu'ici du projet endoflife.date ; Grype lit désormais aussi celle que déclare le fichier de version du système analysé. Passé la fin de vie, il ne signale que les vulnérabilités suivies auparavant par le mainteneur : un rapport vierge sur un tel système ne prouve pas l'absence de faille, et l'alerte doit être traitée comme une lacune de couverture.

Sur un réseau isolé, Grype exige l'import manuel d'une base récente au moins tous les cinq jours avec le réglage par défaut, faute de quoi ses analyses échouent ; Syft fonctionne sans connexion une fois la vérification de mise à jour désactivée. La prise en charge des IPK pourrait étendre l'inventaire aux micrologiciels Linux embarqués qui utilisent ce format.

### Privateer : évaluation automatisée de la sécurité et de la conformité

Privateer : l'OpenSSF a annoncé le 13 octobre 2026 l'entrée dans son bac à sable (*Sandbox*) de ce cadre d'évaluation automatisée de la sécurité et de la conformité, à base d'extensions ; les contrôles déterministes passent d'abord, l'IA est facultative, et ses résultats ne déterminent pas la conformité juridique.

Chaque contrôle ressort réussi, échoué ou « à revoir », ce dernier cas laissant la décision à un humain : l'outil évalue sans bloquer les constructions non conformes, à la différence d'un moteur comme AMPEL.

Des extensions examinent dépôts, configurations, infrastructures et systèmes déployés au regard de catalogues de contrôles tenus à part, comme le référentiel OSPS Baseline.

L'option d'IA de l'extension GitHub transmet les documents déclarés au fournisseur configuré : pour un code soumis au contrôle des exportations, l'industriel doit vérifier qu'un tel transfert est autorisé. Pour les dépôts GitHub, seul le premier niveau de maturité du référentiel est recommandé : les résultats des niveaux 2 et 3, encore en développement, sont à relire. Sans l'option d'IA, l'outil pourrait servir à documenter la préparation au CRA de composants open source.

**EN BREF**

**Plateforme unique du CRA** : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

**Chainguard** : images durcies livrées avec SBOM signé, mises à jour quotidiennes et délai de 7 jours pour les CVE critiques (promesse de l'éditeur).

## SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

*Une faille du noyau Linux rejoint le catalogue des vulnérabilités exploitées ; une extension d'éditeur de code a été piégée sur la place de marché de Cursor ; Chrome annonce le retrait d'une racine d'eMudhra.*

### OVHcloud : versions du CLI officiel piégées sur GitHub

OVHcloud CLI : le 19 octobre 2026, pendant environ une heure et demie, les versions v0.11 à v0.15 de l'outil, distribuées depuis son dépôt GitHub officiel, ont embarqué un binaire qui cherchait les secrets sur l'ordinateur ; une vérification de l'empreinte SHA-256 a révélé l'attaque ; la v0.16 est publiée.

Les versions touchées, parues d'avril à septembre, ont été modifiées après coup ; selon Octave Klaba, l'attaquant a utilisé le compte GitHub d'un développeur.

Les secrets recherchés peuvent être des clés d'API, des jetons d'accès, des identifiants cloud ou des clés SSH.

La version corrective porte un *tag* GitHub signé, et ses fichiers de publication sont désormais déclarés immuables.

Tout poste ou serveur qui a exécuté l'une des versions piégées doit être traité comme exposé : ses clés, jetons et mots de passe techniques sont à révoquer et à renouveler. Un dépôt officiel pouvant distribuer un logiciel malveillant, une chaîne de construction doit aussi figer l'empreinte des binaires tiers qu'elle télécharge. Sans cette précaution, un composant piégé pourrait entrer dans un produit livré, et des secrets volés sur un poste de développement ouvrir l'accès aux dépôts de l'industriel.

### GhostAction : vol d'identifiants par les GitHub Actions, puis par VS Code

GhostAction : selon GitGuardian, cité par The Hacker News, cette campagne de vol d'identifiants vise plus de 30 000 dépôts de 3 000 utilisateurs et organisations, après la compromission d'environ 1 900 comptes GitHub ; une nouvelle étape fait exécuter par VS Code un voleur d'identifiants caché dans une fausse police.



La campagne a tenté d'extraire 3 174 secrets des chaînes d'intégration de dépôts publics, au moyen d'un *workflow* déguisé en audit de sécurité ; GitHub le bloque depuis le 9 octobre.

La seconde étape échappe à ce blocage : elle se passe de GitHub

Actions et persiste après la suppression du *workflow*.

Si l'exécution automatique des tâches est autorisée dans VS Code, ouvrir un dépôt piégé suffit à lancer le voleur sur le poste du développeur : ce réglage est à vérifier, et le propriétaire d'un dépôt touché doit prévenir ceux qui l'ont cloné. Des jetons de publication volés pourraient servir à diffuser des versions piégées de composants open source.

### GitHub : alertes de paquets malveillants étendues à huit écosystèmes

Paquets malveillants : selon une étude de cas de l'OpenSSF du 16 octobre 2026, GitHub a intégré à sa base d'avis les données du dépôt *Malicious Packages* de l'OpenSSF, plus de 238 000 signalements, et couvre désormais huit écosystèmes, dont npm, PyPI, Maven et crates.io.

Ce dépôt public, lancé en octobre 2023, publie ses signalements au format OSV.

Les avis de logiciels malveillants sont publiés automatiquement, sans relecture au cas par cas, par choix délibéré.

Ces alertes restent facultatives : un dépôt dont les alertes Dependabot sont activées doit aussi les demander pour être prévenu qu'une dépendance figure parmi ces paquets. Ouvertes, ces données pourraient être confrontées aux SBOM des produits pour repérer un composant malveillant dans un logiciel déjà livré.

**EN BREF**

**Trivy, 19 mars 2026** : la version 0.69.4 et des actions GitHub de l'outil ont distribué un code volant des secrets.

**Attaque du 11 mai 2026** : 404 versions malveillantes de paquets npm et PyPI, dont TanStack et Mistral AI.

## COMMERCE INTERNATIONAL — Exportations et sanctions

*La règle des affiliés du BIS doit revenir le 10 novembre ; l'OFAC sanctionne Extreme Networks et des réseaux de faux informaticiens nord-coréens ; l'Inde assouplit ses autorisations SCOMET.*

### Règle des affiliés du BIS : réimposition toujours prévue le 10 novembre

Mise à jour, règle des affiliés du BIS : à une semaine de sa réimposition prévue le 10 novembre 2026, aucune prolongation n'est publiée ; selon le cabinet Pillsbury, une prolongation de deux mois, jusqu'au 10 janvier 2027, a été annoncée sans texte du BIS.

Suspendue depuis le 10 novembre 2025, la règle étend les restrictions de l'Entity List aux entités détenues à 50 % ou plus par des entités inscrites.

Tant qu'aucun texte n'est publié, la date du 10 novembre reste celle de la règle en vigueur. Un industriel dont un produit ou une mise à jour relève de l'EAR doit filtrer ses clients selon leur chaîne de détention.

### OFAC : transaction avec Extreme Networks pour des livraisons à une entité bloquée

OFAC, Extreme Networks : le 27 octobre 2026, l'équipementier réseau américain a accepté de payer 1 529 685 dollars pour avoir exporté à neuf reprises, entre 2018 et 2022, du matériel et du logiciel vers une entité bloquée, détenue majoritairement par le groupe russe Almaz-Antey.

Selon l'OFAC, MMZA était bloquée parce que détenue majoritairement par Almaz-Antey, inscrite sur sa liste de sanctions.

L'autorité souligne l'importance de la diligence en matière de sanctions avant l'acquisition d'une entreprise ou de ses actifs.

Le logiciel est traité comme le matériel : les portails de téléchargement et de mise à jour doivent filtrer leurs comptes clients. Une acquisition pourrait faire hériter l'acquéreur de relations avec des entités bloquées.

### OFAC : sanctions contre des facilitateurs des faux informaticiens nord-coréens

OFAC, Corée du Nord : le 28 octobre 2026, l'OFAC a sanctionné dix personnes et une entité pour leur rôle dans les réseaux de faux informaticiens nord-coréens, qui se font embaucher sous de fausses identités par des entreprises des États-Unis et de pays alliés.

Selon le Trésor américain, la Corée du Nord continue de recourir à des documents frauduleux, à des identités volées et à des personnages fabriqués pour placer ses informaticiens dans des entreprises légitimes.

Ces travailleurs à distance financent le régime ; ils peuvent aussi obtenir un accès aux systèmes et au code de leurs employeurs. Le filtrage au titre des sanctions doit donc s'étendre aux sous-traitants du développement logiciel et à leurs intervenants.

### Inde : les autorisations générales SCOMET étendues à de nouveaux exportateurs

Inde, SCOMET : selon l'avis public n° 37/2026-27 de la DGFT du 2 novembre 2026, d'application immédiate, les autorisations générales SCOMET, dont celle des articles de sécurité de l'information, sont étendues aux exportateurs titulaires d'un statut quatre ou cinq étoiles.

La DGFT, direction indienne du commerce extérieur, modifie le chapitre 10 de son manuel des procédures. Les facilités concernées couvrent aussi le stock et la vente, la réexportation après réparation en Inde et les télécommunications. La validité de l'autorisation de réexportation après réparation passe d'un à trois ans.

Les partenaires indiens titulaires de ces statuts peuvent désormais réexporter plus simplement des articles réparés ou de sécurité de l'information.

**EN BREF**

**Royaume-Uni, listes de contrôle** : la mise à jour des contrôles sur les biens, logiciels et technologies militaires et *dual-use* devrait entrer en vigueur début décembre 2026.

**Royaume-Uni, classement** : le service CLC de l'ECJU, suspendu depuis le 12 octobre 2026, doit faire un point d'avancement avant la fin de l'année.

**CMMC** : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

## FRANCE ET UE — NIS2, IA, défense

*Les normes harmonisées de l'AI Act sont attendues pour février 2027 ; la Commission ouvre un deuxième appel SAFE ; la loi Résilience n'est toujours pas réinscrite.*

### AI Act : les normes harmonisées attendues pour février 2027

AI Act, normes harmonisées : selon un compte rendu publié le 28 octobre 2026 par le CEN-CENELEC, la demande de normalisation de la Commission a été révisée après le *Digital Omnibus on AI* et fixe à février 2027 l'échéance des normes harmonisées.

L'article, signé par la Confédération européenne des syndicats, rend compte de la 15e réunion plénière du comité technique JTC 21 sur l'intelligence artificielle, tenue du 6 au 9 octobre à Winterthur. Plusieurs normes seraient en voie d'achèvement à cette date ; la Commission a rappelé le besoin de normes de qualité.

Les règles sur les systèmes d'IA à haut risque de l'annexe III ont été reportées au 2 décembre 2027. Hors l'EN 18286 sur le système de management de la qualité, aucune norme harmonisée ne donne encore de présomption de conformité.

Des normes publiées en février 2027 laisseraient une dizaine de mois aux produits civils ou à double usage concernés.

### SAFE : un deuxième appel de 21,3 milliards d'euros

SAFE : le 29 octobre 2026, la Commission a invité les États membres à un deuxième appel de 21,3 milliards d'euros de prêts pour l'achat de produits de défense, ouvert à tous les États membres.

La Commission demande de donner la priorité aux besoins urgents des forces ukrainiennes et européennes : défense aérienne et antimissile, drones et lutte anti-drones, munitions et missiles. Selon elle, les accords de prêt des 19 États participants ont été approuvés et 16 sont signés ; près de 13,5 milliards d'euros ont été versés à 11 États.

L'appel s'adresse aux États membres et oriente leurs achats vers ces besoins prioritaires. Des commandes financées pourraient en découler, avec les exigences de conformité logicielle des contrats qui les accompagnent.

**EN BREF**

**Loi Résilience** : la conférence des présidents du 27 octobre 2026 n'a pas réinscrit le projet de loi transposant NIS2 ; la suivante se réunit le 3 novembre.

**Omnibus défense** : la directive sur les transferts intra-UE de produits de défense a été adoptée par le Conseil le 9 octobre 2026 et signée le 21 octobre.

## LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

*L'outil REUSE, qui vérifie les avis de licence, rétablit le téléchargement des textes de licence ; aucune décision ni aucun relicenciement n'a été relevé dans les sources consultées.*

### Russie : une suite fondée sur LibreOffice refusée au registre des logiciels nationaux

Russie, droits sur un logiciel dérivé : le 7 octobre 2026, le tribunal d'arbitrage de Moscou a validé le refus du ministère du Numérique d'inscrire « Free Office », de BaseALT, au registre des logiciels russes ; l'éditeur ne détenait pas les droits sur LibreOffice, composant central.

Pour le tribunal, la localisation russe, les dictionnaires et l'intégration de la signature électronique ne suffisaient pas à fonder une propriété indépendante. Selon l'avocat Denis Dorotenko, cinq des sept programmes de la suite sont des développements tiers sous licence ouverte : si le titulaire de l'un d'eux modifiait sa licence ou y mettait fin, l'usage de l'ensemble deviendrait illicite. L'éditeur décrit un ensemble comprenant des suites bureautiques, un client de messagerie et le navigateur Chromium adapté à la cryptographie russe GOST.

L'inscription a des effets concrets : distinct d'un dépôt de droits d'auteur, le registre ouvre des avantages fiscaux sur les licences et les cessions de droits, et facilite l'accès aux marchés publics. Le jugement aborde les licences *copyleft*, la norme d'État russe sur la documentation logicielle et la modification de logiciels.

La décision ne vaut qu'en Russie et peut faire l'objet d'un appel ; elle invite à documenter la part de code propre d'un produit dérivé de composants open source. Une déclaration d'origine ou de propriété d'un logiciel, demandée par un client ou par un programme de production nationale, pourrait être contestée si le produit repose surtout sur de tels composants ; selon Heather Meeker, la décision pourrait peser sur de futurs litiges portant sur le respect des licences open source en Russie.

**EN BREF**

**GPL, SFC contre Vizio** : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

**AGPLv3** : la SFC a publié le 18 mai 2026 sa réponse aux violations de l'AGPLv3 par Bambu Lab ; l'enquête est en cours.

## GLOSSAIRE Sigles et termes cités

**cdxgen** Outil open source du projet CycloneDX qui génère des SBOM pour de nombreux langages et peut fonctionner comme service HTTP.

**CERT-EU** Service de cybersécurité des institutions

**CERT-FR** Centre gouvernemental de veille

**CISA** Agence américaine de cybersécurité et de sécurité des infrastructures

**CLI** Command-Line Interface

**CRA** Cyber Resilience Act

**CycloneDX** Standard de nomenclature des composants (BOM)

**Digital Omnibus** Ensemble de propositions de la Commission de novembre 2025 visant à simplifier les règles numériques de l'UE

**ECJU** Export Control Joint Unit

**eMudhra** Autorité de certification indienne qui délivre des certificats TLS et de signature, dont des autorités intermédiaires reconnues par les navigateurs.

**ENISA** Agence de l'Union européenne pour la cybersécurité

**GitHub** Plateforme collaborative de développement logiciel

**HBOM** Hardware Bill of Materials

**JDK** Java Development Kit

**LiteLLM** Bibliothèque Python open source et passerelle qui donnent accès à de nombreux modèles d'IA par une interface commune.

**NIS2** Directive européenne fixant des exigences unifiées de cybersécurité et de notification d'incidents

**ORT** OSS Review Toolkit

**PHP** Langage de programmation très utilisé

**PyPI** Python Package Index

**SBOM** Software Bill of Materials

**SCANOSS** Outil et service de détection de composants open source et de leurs licences par comparaison d'empreintes de code

**SFC** Software Freedom Conservancy

## AGENDA Dates à surveiller

**10 NOV.** — EXPORT ÉTATS-UNIS
Réimposition automatique de la règle des affiliés du BIS, sauf prolongation

**NOV. 2026** — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

**30 NOV.** — EXPORT ÉTATS-UNIS
Projet publié le 1er octobre 2026 : retrait de certains articles de la liste, définitions révisées, nouvelle exemption de licence

**DÉC. 2026** — EXPORT ROYAUME-UNI
Mise à jour des listes militaire et dual-use (biens, logiciels, technologies) annoncée par l'avis aux exportateurs 2026/24

**9 DÉC.** — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

**DÉC. 2027** — AI ACT
Règles sur les systèmes d'IA à haut risque de l'annexe III, reportées à cette date par le règlement (UE) 2026/1744

**DÉC. 2027** — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

*Software* Compliance
Revue de presse hebdomadaire, N° 5 du 3 novembre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), peut comporter des erreurs : pensez à croiser vos sources.
Édition en ligne avec sources : revue.dejeun.es/2026-11-03
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.